

Manual 22 — Cloud Security Controlled Implementation

Controlled English master — development

****Series order:**** 22

****Primary current reference state:**** Cloud Security Alliance Cloud Controls Matrix (CCM) v4.1

****Boundary:**** Original implementation guidance. Provider-native guidance is implementation evidence, not a substitute for applicable law, independent standards, or CSA control intent. Crosswalks are mappings, not equivalence claims. This manual does not imply CSA STAR registration, attestation, or certification.

1. Cloud governance and operating model

Define executive accountability, cloud security ownership, platform and application responsibilities, risk acceptance, architecture authority, service onboarding, and policy hierarchy. Establish decision rights across security, platform engineering, application teams, privacy, resilience, procurement, finance, and suppliers. Evidence includes cloud governance charter, RACI, policy set, architecture standards, exception authorities, and management decisions.

2. Scope, tenancy, accounts, subscriptions, projects, and landing zones

Maintain authoritative scope for cloud organizations, tenants, management groups, accounts, subscriptions, projects, folders, landing zones, regions, environments, and business owners. Use governed provisioning and naming/tagging to prevent unmanaged estates. Evidence includes tenant/account inventory, ownership, hierarchy diagrams, landing-zone definitions, lifecycle state, and reconciliation against provider inventory APIs.

3. Shared responsibility and contractual allocation

Document security responsibilities by service model, deployment model, provider capability, contract, managed-service boundary, and customer configuration. Do not rely on generic responsibility charts when the actual service or contract allocates duties differently. Evidence includes responsibility matrices, contractual clauses, provider control statements, customer obligations, unresolved gaps, and reassessment triggers.

4. Cloud risk assessment and architecture decision records

Assess cloud risks using data sensitivity, workload criticality, identity paths, internet exposure, provider dependency, regional concentration, supply chain, resilience, legal constraints, and operational change. Record material architecture choices and rejected alternatives. Evidence includes risk assessments, threat models, architecture decision records, assumptions, residual risk, and approvals.

5. Identity federation, authentication, and privileged access

Centralize identity where practicable, enforce strong authentication, constrain privileged roles, separate administrative planes, use just-in-time or time-bounded elevation where supported, and review high-risk access. Protect break-glass identities separately. Evidence includes federation configuration, MFA policies, privileged-role inventories, elevation records, access reviews, break-glass tests, and remediation.

6. Workload identity and machine/service principals

Govern service accounts, managed identities, workload federation, service principals, API identities, certificates, and automated credentials. Prefer short-lived or provider-managed identity mechanisms over static secrets where feasible. Evidence includes workload-identity inventory, ownership, permissions, credential age, trust policies, rotation status, unused identities, and exception records.

7. Network architecture, segmentation, ingress, and egress

Define approved cloud network patterns, segmentation, routing, internet ingress, outbound egress, private connectivity, service endpoints, DNS, management access, and cross-environment communication. Use default-deny or least-connectivity principles where feasible. Evidence includes network diagrams, flow matrices, firewall/security-group policies, route tables, egress controls, tests, and exceptions.

8. Zero Trust patterns and service-to-service trust

Authenticate and authorize connections based on verified identity, workload context, policy, and least privilege rather than network location alone. Govern service meshes, mTLS, API gateways, identity-aware proxies, and policy enforcement points where used. Evidence includes trust architecture, service identities, authorization policies, certificate controls, policy tests, and denied-access observations.

9. Data classification, residency, sovereignty, and lifecycle

Classify cloud data and map where it is created, stored, processed, replicated, backed up, transferred, archived, and deleted. Evaluate residency, sovereignty, contractual, sector, and privacy constraints based on actual applicability. Evidence includes data inventories, classifications, region/location records, transfer paths, retention schedules, and approved location decisions.

10. Encryption, key management, HSMs, and secrets

Define encryption requirements for data at rest and in transit, key ownership, KMS/HSM use, key rotation, access control, separation of duties, backup/recovery, and secret management. Avoid embedding long-lived secrets in code or infrastructure templates. Evidence includes key inventories, key policies, HSM/KMS settings, secret stores, rotations, access logs, and exception treatment.

11. Logging, telemetry, audit trails, and time integrity

Enable relevant administrative, identity, network, data, workload, security-service, and platform audit events. Protect logs from unauthorized change, maintain appropriate retention, and preserve consistent time references. Evidence includes logging standards, enabled sources, ingestion health, retention, immutable/protected destinations where required, time settings, and access controls.

12. Detection engineering, threat monitoring, and CSP-native security services

Develop detections for credential misuse, privilege escalation, suspicious API activity, exposed resources, malicious workloads, data exfiltration, policy changes, and persistence. Use provider-native security tools where useful without assuming product enablement alone provides effective control. Evidence includes detection rules, coverage maps, alert tests, investigations, tuning, and response metrics.

13. Configuration baselines and policy as code

Define approved secure baselines for cloud resources and enforce or evaluate them through policy engines where appropriate. Separate preventive, detective, and advisory policies and control exception handling. Evidence includes baseline definitions, policy repositories, assignments, evaluation results, blocked deployments, waivers, and drift remediation.

14. Infrastructure as code governance and drift control

Manage infrastructure definitions through controlled repositories, review, testing, approvals, protected pipelines, and version history. Detect divergence between declared and deployed state, and govern emergency/manual changes. Evidence includes IaC repositories, reviews, pipeline results, plans, drift reports, manual-change alerts, and reconciliation records.

15. Vulnerability, patch, image, and dependency management

Inventory vulnerabilities across operating systems, packages, images, libraries, managed services, appliances, and application dependencies. Prioritize using exposure, exploitability, workload criticality, compensating safeguards, and provider responsibility. Evidence includes scanner coverage, image findings, patch status, dependency alerts, tickets, exceptions, retests, and provider notices.

16. Container, Kubernetes, and orchestration security

Secure clusters, control planes, nodes, registries, admission, RBAC, namespaces, network policies, secrets, workloads, images, and runtime behavior. Separate platform operator privileges from workload administration. Evidence includes cluster inventories, configuration baselines, admission policies, image provenance, RBAC reviews, runtime alerts, and remediation.

17. Serverless, PaaS, managed-service, and API security

Apply service-specific controls to serverless functions, managed databases, queues, analytics, AI services, APIs, and other PaaS offerings. Govern identity, network exposure, configuration, data handling, logging, versioning, quotas, and provider-managed

responsibilities. Evidence includes service inventories, API policies, configurations, logs, data settings, and service-risk decisions.

18. SaaS security and tenant configuration assurance

Inventory SaaS tenants and govern administrators, federation, MFA, sharing, external collaboration, data retention, integrations, audit logs, applications, and tenant-wide security settings. Evidence includes SaaS inventory, admin-role reviews, configuration assessments, connected-app registers, sharing settings, logs, and remediation plans.

19. DevSecOps, CI/CD, signing, and build integrity

Protect source repositories, runners, build systems, deployment identities, artifacts, registries, and release approvals. Apply branch protections, dependency controls, secret detection, build isolation where appropriate, signing/provenance, and controlled promotion. Evidence includes pipeline definitions, access reviews, security scans, signed artifacts, provenance attestations, and release records.

20. Backup, recovery, immutability, and ransomware resilience

Define protected backup coverage, isolation, immutability where appropriate, retention, cross-account or cross-region strategies, restoration priorities, and credential separation. Test restoration rather than relying only on job success. Evidence includes backup policy, inventory, restore tests, immutable settings, access controls, observed recovery times, and remediation.

21. Availability, regional resilience, and failure-domain design

Design workloads according to required resilience across zones, regions, services, identity dependencies, networks, DNS, data stores, and external suppliers. Explicitly identify single points of failure and recovery assumptions. Evidence includes resilience architecture, dependency maps, failover tests, capacity observations, service limits, and corrective actions.

22. Incident response, forensics, and cloud evidence preservation

Prepare cloud-specific response playbooks for identity compromise, exposed data, malicious workloads, ransomware, cryptomining, control-plane abuse, and provider events. Preserve relevant snapshots, logs, API histories, identities, and volatile evidence while respecting provider capabilities. Evidence includes playbooks, incident timelines, preserved evidence, provider cases, exercises, and lessons learned.

23. Asset inventory, discovery, ownership, and tagging

Continuously identify cloud resources, ephemeral assets, public endpoints, data stores, keys, workloads, images, SaaS integrations, and unmanaged accounts. Require accountable ownership and lifecycle state. Evidence includes inventory feeds, tag-compliance reports, orphaned-resource findings, ownership attestations, and cleanup records.

24. Third-party, marketplace, and managed-service risk

Govern marketplace images, SaaS integrations, managed service providers, external APIs, plugins, and other third-party components. Assess data access, privileges, operational dependency, support, vulnerabilities, incident duties, and exit options. Evidence includes vendor/component register, assessments, permissions, contracts, monitoring, and termination records.

25. Cloud supplier assurance and contractual evidence

Collect provider assurance appropriate to the service and risk, such as independent reports, certifications where relevant, service commitments, architecture information, incident obligations, and subprocessor details. Validate scope and period rather than treating a provider badge as universal assurance. Evidence includes assurance reports, scope mappings, contracts, findings, bridge letters where applicable, and review decisions.

26. Privacy, records, retention, and deletion controls

Implement cloud configurations supporting applicable privacy and records obligations, including purpose limitation interfaces, access controls, retention, legal holds, deletion, export, and evidence of disposal. Distinguish technical capability from legal determination. Evidence includes retention configurations, deletion jobs, legal-hold controls, privacy assessments, and validated lifecycle tests.

27. Cost, capacity, abuse, and resource-governance security interfaces

Treat unexpected cost, resource exhaustion, quota abuse, cryptomining, denial-of-wallet scenarios, and uncontrolled provisioning as security and resilience signals where relevant. Establish budgets, quotas, anomaly detection, and escalation without confusing financial governance with cybersecurity control. Evidence includes thresholds, alerts, capacity data, abuse investigations, and management actions.

28. Multi-cloud and hybrid-cloud control consistency

Define which controls are enterprise-wide and which are provider-specific across cloud, SaaS, on-premises, and edge environments. Normalize evidence without hiding material capability differences. Evidence includes cross-cloud control matrix, identity/network/data patterns, provider-specific deviations, monitoring coverage, unresolved gaps, and migration plans.

29. Metrics, control health, continuous monitoring, and exceptions

Measure control coverage and effectiveness using indicators such as privileged exposure, public resources, policy violations, logging gaps, unpatched risk, stale identities, backup failures, unresolved findings, and exception aging. Evidence includes dashboards, source definitions, thresholds, trends, decisions, exception registers, and remediation tracking.

30. Assessment, assurance, testing, and evidence sampling

Define assessment scope, sampling, technical validation, configuration review, control testing, inherited-control reliance, and assessor interfaces. Automation may collect and test evidence but does not create certification or replace distinct professional judgment required by an external assurance engagement. Evidence includes test plans, samples, workpapers, findings, remediation, and retests.

31. Migration, modernization, exit, portability, and decommissioning

Plan secure migration into, between, and out of cloud services. Address data transfer, identity cutover, key ownership, configuration conversion, dependency replacement, provider exit, evidence retention, and secure decommissioning. Evidence includes migration/exit plans, portability tests, inventory reconciliation, deletion confirmation, revoked access, and residual-data decisions.

32. Evidence package, roadmap, source change, and continuous improvement

For each implemented safeguard record owner, scope, procedure, trigger/frequency, evidence object, test method, findings, remediation, and reassessment trigger. Reverify CCM/CAIQ version, transition dates, mappings, relevant provider guidance, and STAR dependencies at release. Freeze exact English before controlled es-419 and pt-BR localization; mark project translations unofficial; require parity, reproducible six-binary generation, rendered/accessibility QA, SHA-256 provenance, workflow security, exact durable staging, predecessor publication, and catalog/release-registry reconciliation.

Controlled release boundary

This development master does not establish compliance, legal equivalence, provider certification, or CSA STAR status. CCM v4.1 is the controlling current CSA reference state recorded by the source gate; v4.0.x migration information is transitional and must be rechecked before release. Under the repository's canonical rule, a clean candidate with all applicable objective gates green and its predecessor published proceeds under standing release authorization unless a specific documented non-deterministic specialist issue genuinely requires separate judgment.